

Hizmet Reddi (DoS) ve Dağıtılmış Hizmet Reddi (DDoS) Atakları

Siber Saldırı ve Savunma Yöntemleri - Hafta 14



Hizmet Reddi (DoS) ve Dağıtılmış Hizmet Reddi (DDoS) Atakları

Bu sunumda Hizmet Reddi (DoS) ve Dağıtılmış Hizmet Reddi (DDoS) ataklarının temel prensipleri, kullanılan teknikler ve bu saldırılara karşı alınabilecek tedbirler incelenecektir.

Ana Konular:

7.1. DoS Atağı

7.2. DDoS Atağı (Dağıtılmış Hizmet Reddi Atağı)



Anahtar Kavramlar ve Öğrenme Hedefleri

Bu birimde öğrenecekleriniz:

DoS atağının tanımı ve işleyişi.

DoS atak türlerine ait spesifik araçlar.

Bant genişliğine ve belirli hostlara yönelik ataklar.

SYN tekniğiyle gerçekleştirilen DoS atakları.

Mass-Intrusion tekniği ve DDoS.

Formlar üzerinden yapılan DDoS atakları.

DoS ve DDoS saldırıları için alınması gereken önleyici tedbirler.

Anahtar Kelimeler: DDoS atağı, DoS atağı, HULK aracı, LOIC aracı, Mass-Intrusion, SYN taşması.

Hizmet Reddi (DoS) Atağı Nedir?

DoS atağı, bir sistemi kullanılamaz hâle getirmek veya çevrimdışı yapmak amacıyla tasarlanmış bir saldırı türüdür.

Temel amaç, normal kullanıcıların sisteme erişimini engellemektir.

Bu tarz ataklar genellikle çok sayıda kullanıcısı olan sistemleri hedef alır.

Atağın nihai hedefi, hedefi ulaşılamaz yaparak maddi veya manevi zarara uğratmaktır.



DoS Saldırısının İkincil Amaçları

DoS saldırıları sadece erişimi engellemekle kalmaz, aynı zamanda başka bir atağın fark edilmemesini sağlayarak dikkatleri farklı yöne çekmek için de kullanılır.

Örneğin, ön tarafta DoS saldırısı sistemi meşgul ederken, arka planda fidye yazılımı (ransomware) gibi başka bir saldırı gerçekleştirilebilir.

Saldırıları, sistemdeki güvenlik açıklarından, arabellek taşmalarından veya yazılım kaynaklı zafiyetlerden yararlanabilir.

Sistem Kaynaklarının Tükenmesi

DoS saldırıları, bir sistemin işleyebileceği en yüksek miktarda trafik, veri bağlantısı veya bant genişliği gibi eşik değerlerden faydalanır. Çoğu DoS atağı, bir bileşen (RAM, önbellek vb.) tarafından sınırlandırılan bu en yüksek kapasiteyi aşacak şekilde tasarlanır. Sonuç olarak, sisteme gerçekten erişmek isteyen yasal kullanıcılara cevap verilmez. Hedef, itibar kaybı ve hizmet kesintisi yaşar.

Bilgi Güvenliği Üçgeni (CIA Triad) ve DoS/DDoS

Bir ağda bilginin karşıya sorunsuz ulaştığını gösteren temel unsurlar şunlardır:

- Gizlilik (Confidentiality)
- Bütünlük (Integrity)
- Erişilebilirlik (Availability)

DoS ve DDoS atakları, bu unsurlardan 'Erişilebilirlik' kısmını devre dışı bırakarak bilginin bir uçtan diğer uca ulaşmasını engeller.



Yaygın DoS Atak Türleri

DoS atakları farklı türlerde gerçekleştirilebilir. En yaygın DoS atağı türleri şunlardır:

Bant genişliğine yönelik ataklar.

Belirli bilgisayarı (host) ve servisleri düşürmek için yapılan ataklar.

SYN tekniği kullanılarak yapılan ataklar.

Bu atakları gerçekleştirmek için çeşitli araçlar (tools) kullanılır. Bu araçlar genellikle Kali Linux gibi sızma testi ortamlarında incelenir.



Bant Geniřlięi Tüketimi ve Host Düşürme

Yapılan DoS ataęı, çoęu zaman hedefin bant geniřlięini tüketir ve normal kullanıcıları hizmetlere ulaşamaz hâle getirir.
Bu ataklar aynı zamanda bir bilgisayar aşırı aę trafięi nedeniyle aędan düşürmek için de kullanılabilir.



LOIC (Low Orbit Ion Cannon) Aracı Tanıtımı

LOIC aracı, C# dilinde yazılmıştır ve açık kaynak olarak kullanıma sunulmuştur. Windows ve Linux platformlarında kolaylıkla kullanılabilir. LOIC, en yaygın kullanılan DoS ve DDoS araçlarından biri olarak kabul edilir. Bu araç, sızma testi (penetration test) amacıyla sistemlerin DoS saldırılarına karşı dayanıklılığını ve stres testine vereceği tepkiyi ölçmede kullanılır.

LOIC Kullanımı İçin Hazırlık: Mono Aracı

LOIC aracını Linux tabanlı Kali Linux işletim sistemi üzerinde kullanabilmek için 'mono' isimli bir yardımcı araç yüklenmelidir. Mono, programların çapraz platformu desteklemesi için kullanılan bir araçtır. Mono, .Net Framework'ün Linux tabanlı sistemlerde çalışmasını sağlar.

Mono Kurulum Aşamaları

Mono aracı belirli aşamalarda kurulur.
Kurulum tamamlandıktan sonra, uygun komut dizimi ile LOIC aracı çalıştırılabilir.
Örnek komutlar ve adımlar, Kali Linux ortamında gösterilmektedir.

LOIC Kullanıcı Arayüzü Genel Bakış

LOIC aracı çalıştığında grafiksel bir kullanıcı arayüzü ile karşılaşılır. Bu arayüz, atağın konfigürasyonu ve izlenmesi için beş temel alana ayrılmıştır.

LOIC Arayüz Alanı 1: Hedef Belirleme

1 No.lu Alan:

Bu alanda atağın yapılacağı web sitesinin URL kısmı doldurulur.
Ayrıca, doğrudan IP adresi hedef alınacaksa, IP bilgisi ilgili kısma yazılır.

LOIC Arayüz Alanı 2: Atak Başlatma ve Sonlandırma

2 No.lu Alan:

Tüm ayarlamalar yapıldıktan sonra 'IMMA CHARGIN MAH LAZER' butonu ile atak başlatılır.

Atak, 'Stop Floading' yazısına tıklanarak sonlandırılır.

LOIC Arayüz Alanı 3 ve 4: Bilgi ve Parametreler

3 No.lu Alan: Seçilen hedef hakkında bilgilerin yer aldığı bölümdür.

4 No.lu Alan: Atak parametrelerinin ayarlandığı bölümdür. Bu alandan kritik ayarlar yapılır:

Port numarası.

Kullanılacak metot (TCP, UDP, HTTP).

Atağın hızı (speed).



5 No.lu Alan:

Atak sırasında atak ile ilgili detaylı bilgilendirmelerin olduğu bölümdür.

İlgili sütunlar altında görülen değerler:

Idle değeri.

Bağlantı durumu (connecting).

İstek durumları (requesting, requested).

İndirme bilgileri (downloading, downloaded).

LOIC ile DDoS Yeteneđi ve Botnet Yönetimi

LOIC aracı, DDoS saldırısı gerçekleřtirmek için diđer bilgisayarlarla haberleřebilir.

Aynı zamanda zombi makineleri de yöneterek daha büyük zararlar verebilecek DDoS atakları gerçekleřtirebilir.

Zombi Makineler: Zararlı yazılım enjekte edilmiř cihazlardır. Saldırgan bu cihazları uzaktan yönetir.



OWASP SwitchBlade Aracı Tanıtımı

OWASP SwitchBlade, hizmet reddi atağı gerçekleştiren bir başka araçtır. Eski adı DoS HTTP POST olarak bilinir. Bu araç, sitelerdeki DoS ataklarına karşı test için yazılmış olsa da kötü amaçlı saldırganlar tarafından kullanılabilir. Araç, DoS saldırı tiplerini seçmeye ve karmaşık parametreler ayarlamaya olanak tanır.



SwitchBlade Arayüz Alanı 1: Atak Tipi Seçimi

1 No.lu Alan: Bu alanda üç farklı atak tipi seçilebilir:

Slow headers

Slow POST

SSL Renegotiation



Slow Headers Atak Tipi

Bu atak tipi seçildiğinde araç, çok yavaş bir hızda HTTP başlıkları (headers) gönderir.

Ancak hiçbir zaman verinin tamamını göndermez.

İletişimi sonlandırmamak için ara ara başlık bilgilerini göndermeye devam eder.

Bu durum, sunucunun tüm kaynaklarının (bellek ve bağlantı havuzu) meşgul olmasına neden olur.



Slow POST Atak Tipi

Saldırgan, bu atak tipinde web sitesinin form alanlarına POST işlemi yapacaktır.

Form verilerini çok yavaş bir hızla iletir.

Sunucu, daha fazla veri geleceğini zannederek bağlantıyı açık tutar.

Bu durum, sunucunun kaynaklarının (özellikle bağlantı kuyruğu) tükenmesine neden olur.



SSL Yeniden Anlaşma (SSL Renegotiation) Atak Tipi

Bu atak tipinde saldırgan, devamlı yeni SSL anlaşmaları (renegotiation requests) gönderir.

SSL/TLS anlaşmaları yoğun CPU gücü gerektirir.

Amaç, sürekli yenilenen bu anlaşmalarla sunucunun tüm CPU gücünü tüketmeyi sağlamaktır.



SwitchBlade Arayüz Alanı 2: Karmaşık Parametreler

2 No.lu Alan: Burada aracın daha karmaşık çalışmasını sağlamak için çeşitli parametreler bulunur.

Bu parametreler:

Bağlantılar (connections): Aynı anda kurulacak bağlantı sayısı.

Bağlantı hızı (connection rate).

Zaman aşımı (timeout) değeri.



SwitchBlade Arayüz Alanı 3: Kontrol Butonları

3 No.lu Alan: Bu kısımda aracı çalıştırmak ve araçtan çıkmak için butonlar bulunur.

Gerekli atak tipleri ve parametreler girildikten sonra 'Run attack' butonuna basılarak atak başlatılır.

'Quit' butonuyla da araçtan çıkılır.



HULK (HTTP Unbearable Load King) Aracı

HULK, belirli bir hostu hedef alabildiği gibi, bir web sitesine de hizmet reddi atağı başlatabilir.

Temel amaç, sitenin veya hedefin stres testini ölçmektir.

Bu araç, Python dilinde yazılmıştır ve tüm işletim sistemlerinde çalışabilir.



HULK Aracının Tehlikesi ve Hedefleri

HULK aracı; yönlendirici (router), anahtar (switch) ve güvenlik duvarı (firewall) gibi ağ cihazlarını test etmek için kullanılabilir. Aynı zamanda sunucuların IP havuzlarına direkt atak yapabilir. Bu yetenekleri nedeniyle HULK, çok tehlikeli bir araç olarak sınıflandırılır.

HULK Kurulumu

HULK aracı, Github depoları klonlanarak indirilir.
Kurulum işlemi bittikten sonra, aracı kullanmak için indirildiği dizine (örneğin 'Home' dizini) gidilmelidir.
'git clone' komutu kullanılarak araç Kali Linux işletim sisteminde ilgili dizine indirilir.

HULK Aracının Çalıştırılması

Kurulum sonrasında HULK aracının indirildiği dizine erişilmelidir. Bu dizinde farenin sağ tuşuna basılarak 'Open in Terminal' seçeneği seçilir. Aracı çalıştırmak için 'hulk.py' programı kullanılır ve parametre olarak hedef IP adresi belirtilir.

HULK Çalıştırma Kod Söz Dizimi

HULK aracını çalıştırmak için gerekli olan temel kod söz dizimi:

'sudo' komutu: Linux sistemlerde geçici root kullanıcı haklarına sahip olmak için kullanılır.

'python' komutu: Python'u başlatmak için kullanılır.

'hulk.py': Hulk aracının Python kodlarını içeren ana dosyasıdır.

Hedef bilgisi: Hedef bilgisayar IP ve port bilgisi komutun sonuna eklenir.

HULK Saldırısının Etkileri

HULK aracı çalıştırıldıktan sonra hedef sistemde işlemci, RAM ve Wi-Fi ağındaki işlem yükünde ciddi bir artış görülür. Bu artış, sistemin normal taleplere yanıt veremeyecek kadar meşgul olduğunu gösterir.



HULK Saldırısı Sonrası Durum

HULK aracı kapatıldıktan (atak sonlandırıldıktan) sonra, işlemci, RAM ve Wi-Fi kaynaklarının kullanımı hızla normal seviyelere döner.

HULK Performans Parametreleri

HULK aracının performansını artırmak veya azaltmak için iki ana parametre kullanılır:

HULKMAXPROCS: Bu parametre ile bağlantı havuzu ayarlanabilir. Varsayılan değeri 1024'tür.

GOMAXPROCS: Bu parametre ile atak yapması istenen işlemci sayısı artırılıp azaltılabilir.



SYN Taşması (SYN Flood) Atak Yöntemi

Bilgisayarlar arasında iletişim, TCP ve UDP olmak üzere iki farklı protokol kullanılarak sağlanır.

TCP protokolü, bağlantı kurmak için 'Üç Yollu El Sıkışma' (Three-Way Handshake) tekniğini kullanır.

Bu teknik, SYN, SYN/ACK ve ACK mesajları göndererek güvenilir bir TCP bağlantısının başlamasını sağlar.



Üç Yollu El Sıkışma Adımları

1. İstemci (PC1) bir SYN paketi ile iletişim kurma isteğini iletir.
2. Sunucu (PC2) paketi aldıktan sonra, isteği kabul ettiğini belirten bir SYN/ACK paketi gönderir.
3. İstemci son olarak, sunucudan paketin alındığını onaylamak için bir ACK paketi gönderir ve iletişim başlar.

SYN Taşması Saldırı Mekanizması

Saldırgan (istemci), normal bir şekilde iletişimi başlatmak için SYN paketini gönderir.

Sunucu, normal bir şekilde SYN/ACK paketiyle cevap verir.

Ancak saldırgan, göndermesi gereken son ACK paketini kasıtlı olarak göndermez.

Bunun yerine sürekli olarak yeni SYN paketlerini göndermeye devam eder.

Sunucu Kaynaklarının Tükenmesi

Saldırgan ACK paketini göndermediği için sunucunun ilgili portu, gelecek ACK paketini beklemeye başlar.

Sunucu, iletişimin başlayacağını varsayarak ilgili portunu belirli bir süre (varsayılan olarak 120 sn.) açık tutar.

Saldırganın sürekli SYN göndermesi sonucu, açık olan port sayısı hızla artar ve sunucunun kaynakları tükenir.

Normal bir kullanıcı iletişim başlatmak istediğinde, ona ayıracağı port kalmaz ve sunucu cevap veremez duruma gelir.



Hping3 Komutu: Gelişmiş Ping Aracı

Hping, komut satırında kullanılabilen ve ping komutunun gelişmiş versiyonu olan bir TCP/IP paket oluşturma ve çözme aracıdır.

Ping komutundan farkı, sadece ICMP yankı isteklerini göndermemesi, aynı zamanda TCP, UDP, ICMP ve RAW-IP gibi protokolleri de desteklemesidir.

Hping komutunun en yeni sürümü hping3'tür.



Hping3 Kurulum ve Versiyon Kontrolü

Hping3 komutu, Kali Linux içinde hazır olarak gelmektedir. Sistemde hping3'ün yüklü olup olmadığını kontrol etmek için versiyon bilgisi öğrenilebilir. Eğer yüklü değilse, paket yönetim komutları kullanılarak kurulum yapılır.



Hping3 Parametreleri ve Kullanımı

Komut satırına ilgili yardım komutu yazılarak hping3 ile kullanılabilecek tüm parametrelerin listesi ve görevleri görülebilir.
Bu sayede kullanıcılar, farklı saldırı vektörleri için gereken ayarları yapabilirler.



Hping3 ile SYN Atağı Başlatma

SYN atağını başlatmak için hping3 komutu belirli parametrelerle birlikte kullanılır.

- sudo: Komutu çalıştırmak için geçici root yetkisi sağlar.
- hping3: Ana komuttur.
- S: Atağın SYN paketi ile olacağını belirtir.
- flood: Cevaplar beklenmeden paketlerin art arda ve hızlı bir şekilde gönderilmesini sağlar (Taşma).
- p: Hedef port numarasını belirtir.

Saldırının İzlenmesi: Wireshark

Saldırı başlatıldığında hedef bilgisayarın işlemci performans göstergesi 100'lere kadar çıkabilir.

Bu durum, sistem kaynaklarının boşa kullanıldığı ve normal işlemlerin gerçekleşemeyeceği anlamına gelir.

Hedef bilgisayarda neler olup bittiği, paket yakalama ve analiz yazılımı olan Wireshark ile izlenebilir.



Wireshark ile SYN Paket Analizi

Atak başlatılmadan önce Wireshark programı açılır ve ağdaki trafiği dinlemesi sağlanır.

Analizde, belirli bir kaynak IP'den (saldırgan) hedefe çok hızlı bir şekilde SYN paketlerinin gönderildiği görülür.

Bu hızlı paket akışı, karşıdaki bilgisayarın portlarını hızla doldurur ve hedefin yanıt veremez hâle gelmesine neden olur.

Wireshark, SYN bayrağının aktif edildiğini gösterir.

Dağıtılmış Hizmet Reddi (DDoS) Atağı Tanımı

DDoS atağı, DoS atağının gelişmiş bir versiyonudur. DDoS, tek bir kaynak yerine birden fazla dağıtılmış kaynaktan (genellikle zombi bilgisayarlar) geldiği için çok daha yıkıcı ve tehlikelidir.

DDoS Organizasyon Yöntemi 1: Koordineli Saldırganlar

Bu yöntem, illegal sitelerde buluşan çok sayıda saldırganın seçilen hedefe belirli bir gün ve saatte, atak araçlarını kullanarak saldırmasıyla gerçekleştirilir. Ancak bu yöntem, koordinasyon zorluğu nedeniyle pek tercih edilmez.



DDoS Organizasyon Yöntemi 2: Botnet Kullanımı (Tercih Edilen Yöntem)

Bu yöntemde, saldırganlar önce ağ içindeki savunmasız sistemleri bulur ve o sistemlere zararlı yazılım (malware) enjekte eder.

Bu şekilde saldırganlar, 'zombi' olarak tabir edilen bilgisayarlar edinir ve bir 'Botnet' kurar.

Saldırgan, zombileri kullanarak istediği zaman diliminde herhangi bir sisteme atak yapabilir ve kendini gizleyebilir.

Zombi Bilgisayar ve Botnet Kavramları

Zombi Bilgisayar: Bir saldırgan tarafından virüs veya Truva atı gibi zararlı bir yazılım yüklenmiş bilgisayarlardır.

Saldırgan, kullanıcının farkında olmadan bu bilgisayarı uzaktan yönetir ve çeşitli ataklar gerçekleştirebilir.

Botnet: Robot ve Network kelimelerinin birleşimidir. Zombi bilgisayarlardan kurulan bu orduya verilen isimdir.



Mass-Intrusion (Kitleseel Saldırı) Fazı

Saldırganın önce savunmasız sistemleri bularak onlara zararlı yazılım enjekte etmesi ve zombi bilgisayarlar edinmesi yöntemi, 'Mass-Intrusion faz tekniğı' olarak da adlandırılır.

Mass-Intrusion fazı, DDoS ataklarının ilk ve hazırlık aşamasını oluşturur.



Slowloris Aracı Tanıtımı

Slowloris aracı, adını çok yavaş hareket eden bir hayvandan (lorigiller) almıştır.

Python dilinde yazılmıştır ve açık kaynak olarak Github'da mevcuttur.

Bu araç, HTTP istek (request) ve HTTP yanıt (response) paketlerinin iletiminden kaynaklanan açığı kullanarak çalışır.

Normal HTTP İletişimi

Normalde sunucuya bir HTTP isteği gönderildiğinde, sunucudan tam ve zamanında yanıt gelir.
İstemci ve sunucu, istek/yanıt döngüsünü tamamlayarak bağlantıyı sonlandırır.



Slowloris Saldırı Mekanizması

Slowloris aracı, sunucuya isteği tek seferde değil, parçalar (kısmi HTTP paketleri) hâlinde gönderir.

Sunucu, isteklerin tamamlanacağını düşünerek bağlantıyı sürdürür ve portu açık tutar.

Slowloris, bağlantıyı canlı tutmak için bu kısmi paketleri göndermeye devam eder.



Slowloris'in Etkisi ve Tespit Edilememesi

Sonunda sunucuya ayrılan tüm bağlantı portları tüketilir. Normal bir kullanıcı sunucuya ulaşmak istediğinde kaynaklar tükendiği için erişemez. Slowloris, 'düşük ve yavaş' atak sınıfına girdiği için saldırı tespit sistemleri (IDS) tarafından tespiti zordur (eksik paketler gönderir). Ayrıca, günlük (log) oluşturmayı engelleyerek siber güvenlik analistlerinin işini güçleştirir.

Slowloris Kullanımı ve Soket Bağlantıları

Slowloris aracı, uygun komut dizimi ile çalıştırılır. Komut parametresiz kullanıldığında varsayılan olarak 150 soket bağlantısı gerçekleştirir. '-s' parametresi, soket bağlantı sayısını varsayılan değerden farklı bir değere ayarlamak için kullanılır (Örneğin, '-s 500' ile soket sayısı 500'e ayarlanır).

Slowloris'in Loglara Etkisi

Slowloris saldırısı sırasında Apache2 gibi web sunucusu günlükleri incelendiğinde sayfalarca kayıt oluşturulduğu görülür. Bu aşırı günlük kaydı, sunucunun sürekli meşgul edildiğini ve anormal trafik yoğunluğunu gösterir.



RUDY (RU-Dead-Yet) Aracı Tanıtımı

RUDY aracı, diğer araçlar gibi hızlı istekler ile sunucuyu meşgul etmek yerine, uzun form alanları göndererek web sunucusunu hizmet veremez duruma getirmek için kullanılır.

Bu yöntem, özellikle web uygulaması katmanında DoS/DDoS saldırıları düzenler.



Normal HTTP Form İletişimi

Normal bir iletişimde, istemci form alanlarına ait bilgileri HTTP Post isteği ile gönderir.
Sunucu da form bilgilerini alır ve HTTP yanıt bilgisini göndererek işlemi tamamlar.



RUDY Saldırı Mekanizması

RUDY öncelikle hedef web sayfasındaki form alanlarını tarar.
Normal bir HTTP Post isteği oluşturur, ancak bunun çok uzun bir POST isteği olacağını belirten bir başlık bilgisi gönderir.
Sonrasında form verilerini çok küçük paketlere (1 Byte – 10 KB arası) böler.



RUDY'nin Kaynak Tüketimi

RUDY aracı, küçük paketleri 10 saniyelik rastgele aralıklarla sürekli sunucuya gönderir.

Sunucu, yavaş bağlantı hızına sahip bir kullanıcıdan bilgi aldığını zannederek bağlantıyı açık tutar (keep-alive).

Bu durum, sunucunun işlemesi gereken trafiğin maksimum boyuta çıkmasına ve normal kullanıcıların isteklerinin reddedilmesine neden olur.



RUDY Aracının Kurulumu ve Komutları

- RUDY aracı da diğer araçlar gibi komut satırı üzerinden yüklenir.
RUDY komutu kullanılırken bazı parametreler zorunlu veya isteğe bağlıdır:
- t (Target/Hedef): IP adresi veya web sitesi (Zorunlu komuttur).
 - d (Delay/Gecikme): Gönderilen her bayt arasındaki bekleme süresi (isteğe bağlı).
 - n (numberOfConnections): En fazla bağlantı sayısı (isteğe bağlı).

DoS ve DDoS Ataklarını Önleme: Genel Yaklaşım

DoS ve DDoS atakları, TCP, UDP, ICMP, HTTP gibi yasal protokollerin iletişim kurarken ortaya çıkardığı açıkları kullandıkları için kesin çözümü yoktur. Bu ataklar yasal iletişimi taklit eder, ancak eksik veya fazla paket gönderir. Alınan her güvenlik adımı, yavaş bağlantısı olan normal kullanıcıları da ister istemez etkileyecektir, çünkü sunucular sahte paketler ile yasal paketleri ayırt edemez.



Ağ Cihazları ve Yazılımlarla Savunma

Saldırı Önleme Sistemleri (IPS): Aynı IP'den art arda gelen istekleri reddedebilir ve zaman aşımına (timeout) göre paketleri düşürebilir.

DoS Savunma Sistemleri (DDS): IPS'lerin DoS atakları için oluşturulmuş özel bir versiyonudur. SYN atağı ve düşük ve yavaş atak sınıfındaki saldırılar için etkili olabilir.



İnternet Servis Sağlayıcısı (ISP) ve Yönlendirici Tedbirleri

İnternet Servis Sağlayıcılarından (ISP) destek alınabilir. ISP'ler sahip oldukları teknolojiler gereği atağı iç ağa ulaşmadan önleyebilirler. Yönlendirici (Router) konfigürasyonunda Erişim Listeleri (Access List) ile daha kapsamlı kurallar tanımlanabilir.

Ağ Trafiği Yönetimi: Kara Delik Yönlendirmesi

Ağda anormal bir trafik sezildiğinde, ağ trafiği 'kara delik' (black hole) denilen boş bir IP adresine yönlendirilebilir. Bu durum, ağ trafiğini rahatlatır ancak gerçek kullanıcıları da olumsuz yönde etkileyerek hizmeti tamamen keser.



Bağlantı Sınırlamaları ve IDS Kullanımı

Bir IP'den gelen bağlantı isteği sayısı sınırlandırılmalı ve bağlantı süresi ağın karakteristiğine göre ayarlanmalıdır.

Saldırı Tespit Sistemleri (IDS) kullanılarak trafikteki dalgalanmalar tespit edilmeli ve trafik yoğunluklarının önüne geçecek kurallar yazılmalıdır.



Varsayılan Parametrelere Karşı Önlem

Atak araçlarının kullandığı varsayılan parametrelere göre bir güvenlik tedbiri almak faydalı olacaktır.

Bu sayede, aracın karmaşık kullanımını bilmeyen ve sadece varsayılan ayarları kullanan düşük seviyeli saldırganlardan korunmak mümkündür.

Yedekli Sunucu Kullanımının Sınırlılıkları

Sunucuları yedekli olarak kullanmak kısmi bir çözüm olsa da, doğrudan DDoS/DoS atağı anında işe yarayan bir yöntem değildir. Atak, tüm yedekli kaynakları aynı anda hedef alacak kadar büyükse, hizmet yine kesilecektir. Ancak felaket senaryoları için yedeklilik önemlidir.

Hizmet Reddi (DoS) ve Dağıtılmış Hizmet Reddi (DDoS) Atakları

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

